

CS304: PROGRAMMING ON THE WEB

DR. DALIA RIZK



جامعة الأهرام الكندية
AHRAM CANADIAN UNIVERSITY

WEB DEVELOPMENT PROCESSES & SECURITY

- ❑ Web Development Processes

- ❑ Security tools

WEB DEVELOPMENT PROCESSES

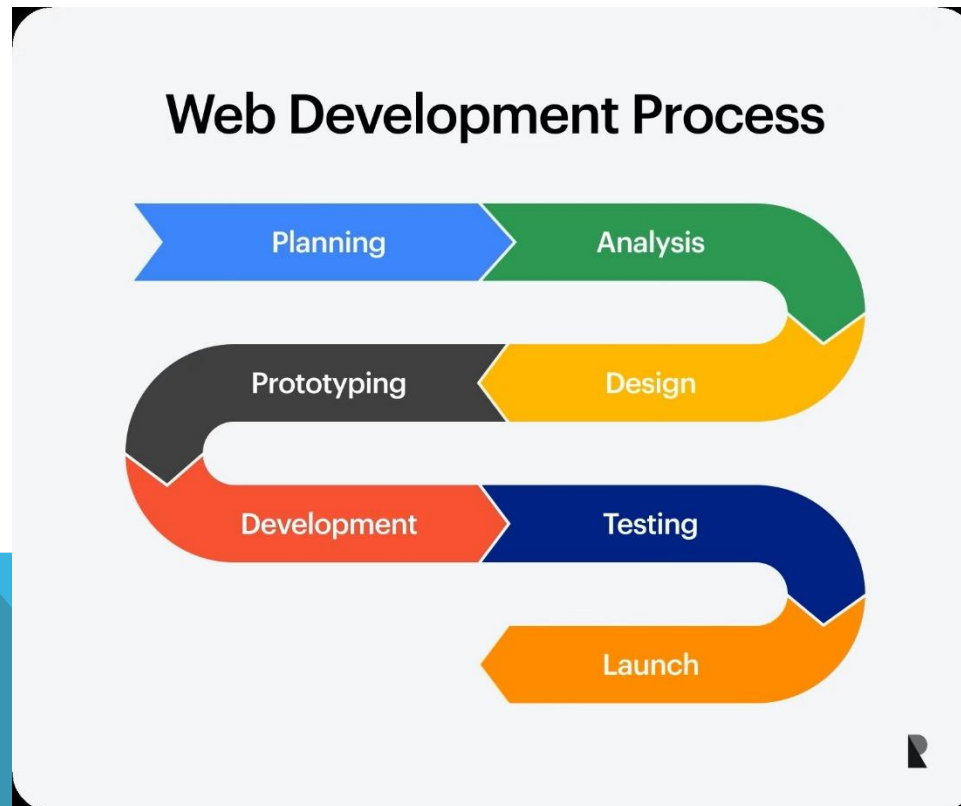
- ❑ Web development follows an iterative process:
 - Discovery / Planning: Defining project goals, user personas, and technical requirements
 - Design & Prototyping: Creating wireframes and user interface (UI) designs (using tools like Figma)
 - Build:
 - Frontend: Creating the user-facing part with HTML, CSS, JavaScript, and frameworks like React, Angular, or Vue
 - Backend: Building server-side logic, APIs, and database interactions using Node.js, Python (Django), or PHP

WEB DEVELOPMENT PROCESSES – CONT'D

- ❑ Web development follows an iterative process:
 - Testing: Ensuring functionality, performance, and security (Jest, Selenium)
 - Deployment: Launching to servers (AWS, Vercel) using DevOps tools (Docker, CI/CD pipelines)
 - Maintenance: Monitoring performance, fixing bugs, and updating dependencies
- ❑ Using **frontend** (HTML/CSS/JS/React) and **backend** (Node.js/Python/PHP) technologies to create secure applications

WEB DEVELOPMENT PROCESSES – CONT'D

- ❑ Key tools include Git for version control, VS Code for editing, and security measures like Content Security Policy (CSP), CORS, and server-side framework protections to prevent vulnerabilities



SECURITY TOOLS - PROBLEM

- ❑ Rising Complexity: As web applications become more complex (SPAs, APIs, Microservices), the attack surface expands exponentially
- ❑ Primary Goals: Confidentiality, Integrity, and Availability
- ❑ Types of Web Threats:
 - Injection Attacks (SQLi, XSS, NoSQL, OS)
 - Broken Access Control
 - Supply Chain Vulnerabilities
 - Cryptographic Failures
 - Insecure Design
 - Security Misconfiguration

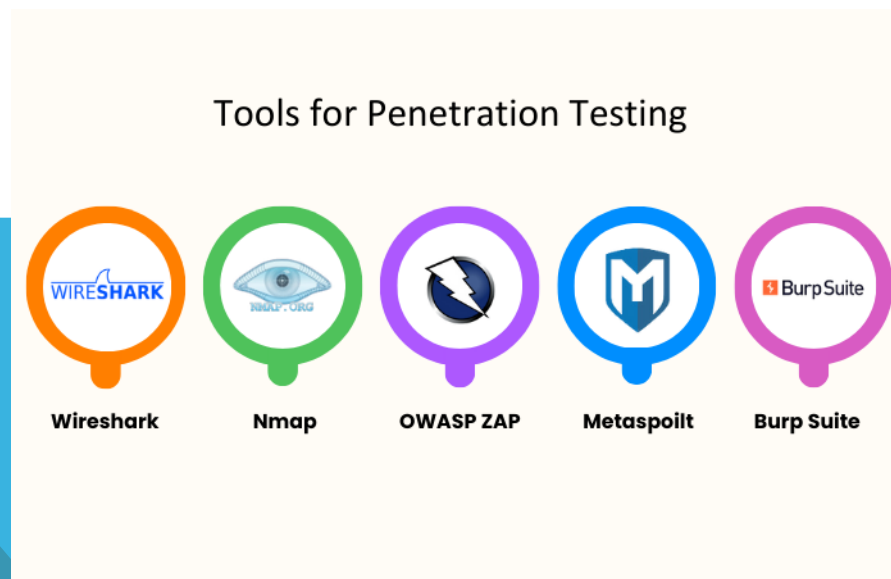


SECURITY TOOLS - PRACTICES

- ❑ **Framework Protections:** Using built-in security features in frameworks like Django or Laravel to prevent SQL injection and CSRF.
- ❑ **Content Security Policy (CSP):** Header that restricts which resources (scripts, images) can be loaded, mitigating XSS.
- ❑ **CORS (Cross-Origin Resource Sharing):** Configuring policies to safely allow external domains to access API resources.
- ❑ **Vulnerability Scanning:** Using tools like OWASP ZAP or Burp Suite to identify weaknesses.
- ❑ **HTTPS:** Using SSL/TLS certificates for data encryption in transit.
- ❑ **Dependency Management:** Regularly checking for vulnerable libraries in `node_modules` using tools like `npm audit`.

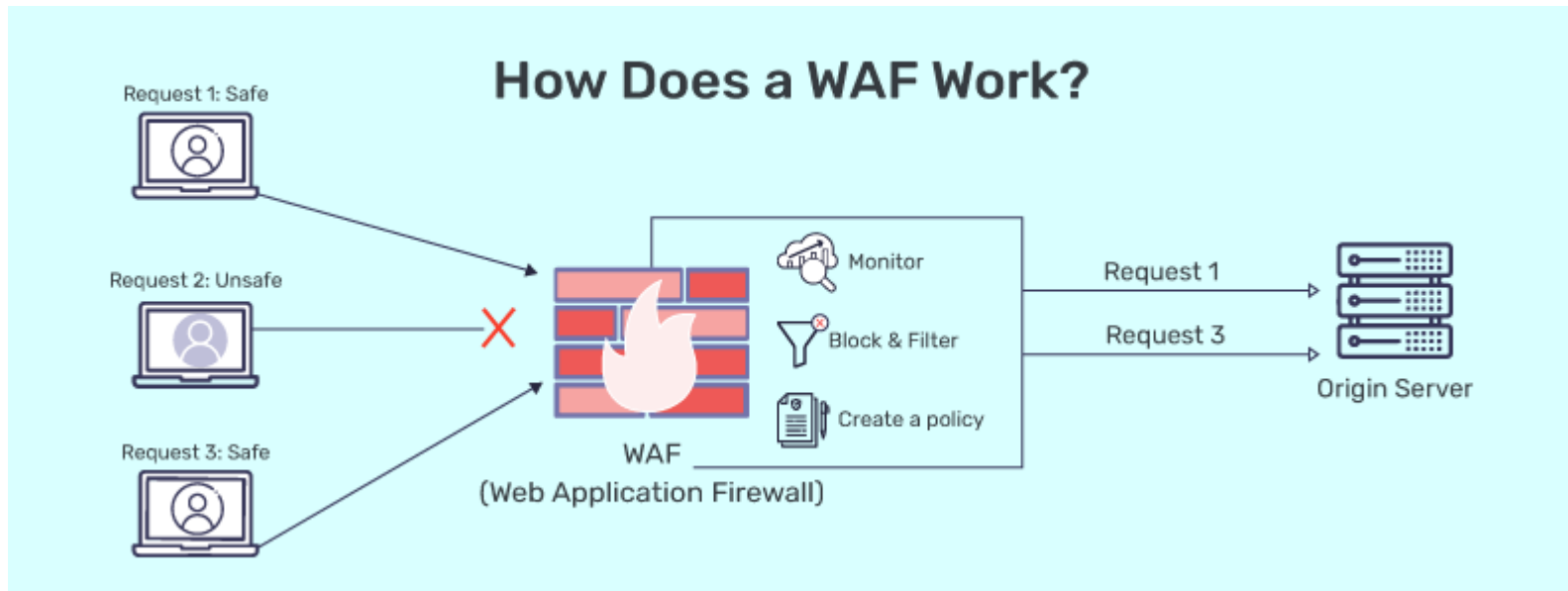
PENETRATION TESTING TOOLS

- ❑ **Burp Suite:** The industry-standard intercepting proxy for manual web application security testing.
- ❑ **OWASP ZAP:** An open-source, automated tool for finding vulnerabilities during development and testing.
- ❑ **Metasploit:** Framework used to validate vulnerabilities by attempting actual exploits.
- ❑ **Nmap:** Network mapper used for port scanning and service discovery.



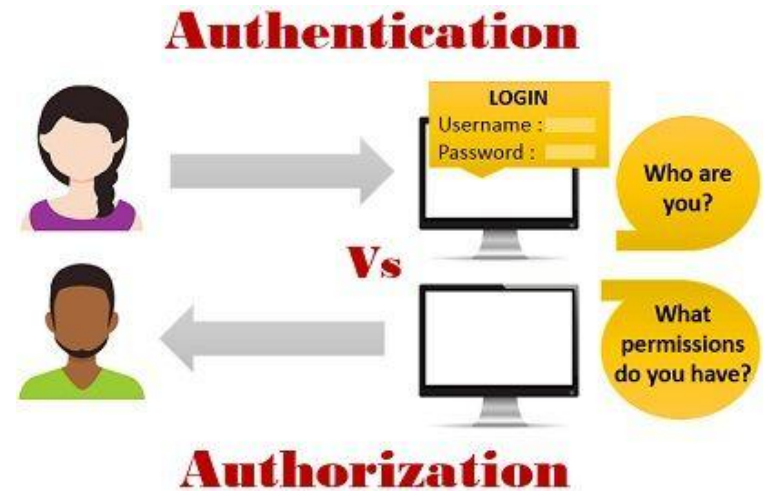
WEB APPLICATION FIREWALL (WAF)

- ❑ A WAF monitors and filters HTTP traffic between a web application and the Internet. It protects against XSS, SQLi, and cookie poisoning



AUTHORIZATION VS. AUTHENTICATION

- ❑ **Authorization:** OAuth 2.0 provides delegated access. It allows a user to grant a website access to their info on another site without giving them the password.
- ❑ **Authentication:** OpenID Connect (OIDC) is a simple identity layer on top of the OAuth 2.0 protocol. It verifies the identity of the end-user.



Feature	Authentication (AuthN)	Authorization (AuthZ)
Question	Who are you?	What can you do?
Challenge	Credentials (Pass, Biometric)	Permissions (Scopes, Roles)
Protocols	OIDC, SAML, LDAP	OAuth 2.0, RBAC, ABAC

DATA PROTECTION

❑ **Encryption:** Protecting data while it travels over the network and while it sits on disks:

- HSTS: Forces browsers to communicate over HTTPS only.
- AES-256: Standard for symmetric encryption at rest.

❑ **Content Security Policy (CSP):** is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. It prevents the browser from loading malicious resources from unauthorized domains

```
Content-Security-Policy: default-src 'self'; script-src 'self' https://trustedscripts.com;
```

LOGGING AND MONITORING

“If you can’t see it, you can’t secure it”

❑ Centralized logging (ELK Stack) and Real-time monitoring are critical for incident response:

- Audit Trails (WORM storage)
- Anomaly Detection
- Real-time Alerting
- Forensics Analysis

